Introduction au droit de l'informatique

ENSIIE

Feuille de décisions : exemple

Cet exemple illustre une manière de remplir une rubrique, sur un cas fictif. Il constitue une possibilité de **démarche**, et en aucun cas une réponse attendue : une décision opposée, aussi bien justifiée, obtiendrait la même note. Il s'agit d'un exemple abouti : vos rendus pourront être moins détaillés, du moment que les informations essentielles y figurent : une demi-page par présentation suffit, en phrases courtes, même sans verbe, mais sans abréviations, hormis les sigles usuels (RGPD, NIS 2, CNIL, STAD, etc.).

Ce qui rend cette feuille réussie : les faits viennent tous de l'exposé ou des réponses du groupe ; les hypothèses et les points ignorés sont isolés, et l'hypothèse décisive est signalée : le niveau de confiance est la probabilité qu'elle soit exacte, et la feuille précise quelle décision serait prise si elle était fausse. Les règles de droit figurent dans les risques, tandis que la qualification juridique incertaine (Tranzolis est-il sous-traitant ?) figure dans les hypothèses. Les trois options sont réellement défendables, y compris celle qui obéit à la consigne. Chacune est examinée sur les trois dimensions. La décision est assez précise pour être exécutée, et le risque accepté est concret et assumé.

Le cas fictif

L'entreprise. Névé & Lacets est une PME de vente en ligne de matériel de randonnée : 40 salariés, dont une équipe technique de cinq personnes, et environ 2 000 commandes par mois. Toutes sont livrées par Tranzolis, un transporteur national, dans le cadre d'un contrat signé il y a trois ans. Ce contrat porte sur le transport et le suivi des colis ; il ne contient aucune clause sur les données personnelles. Le directeur général le renégocie lui-même : la première réunion a lieu mardi prochain, et il espère obtenir une baisse de tarif de 10 %.

Le projet. Léa, alternante en première année d'école d'informatique, est arrivée il y a cinq semaines. Elle travaille en entreprise du lundi au jeudi et suit les cours le vendredi. Sa mission : remplacer la saisie manuelle des expéditions par l'API de Tranzolis. Pour chaque commande, le site transmet à l'API le nom, l'adresse, le téléphone et les instructions de livraison du client ; l'API renvoie un numéro de suivi, que le client reçoit par courrier électronique sous la forme d'un lien vers le portail public de Tranzolis. Ce portail n'exige aucune authentification : le numéro figure en clair dans l'URL.

L'incident. Jeudi à 16 h, Léa passe une commande de test à son propre nom et ouvre le lien de suivi. Par curiosité, elle modifie les derniers chiffres du numéro dans l'URL. La page affiche alors le nom, l'adresse, le téléphone et les instructions de livraison d'un autre destinataire (« digicode 4521B, laisser chez la voisine »). Elle essaie trois numéros : chaque fois, les données d'un inconnu s'affichent, et l'une des adresses correspond à un client de Névé & Lacets. Elle fait deux captures d'écran, enregistrées sur son ordinateur professionnel, puis s'arrête.

La réaction. Sa tutrice, responsable technique et référente RGPD de l'entreprise, est en congé jusqu'à lundi. Léa en parle au lead développeur, qui participera à son évaluation de fin de période. Il lui répond : « Ce n'est pas notre système. On renégocie le contrat avec eux la semaine prochaine : ne fais pas de vagues, on verra lundi. » Il est 16 h 30 ; Léa quitte l'entreprise à 18 h et ne reviendra que lundi.

Les décisions à prendre. Léa doit décider s'il faut faire remonter la faille dès aujourd'hui malgré la consigne, et à qui ; si Tranzolis doit être prévenu, par qui et comment ; et ce qu'elle doit faire de ses captures d'écran.

© Frédéric Connes, 2026 · Tous droits réservés

Cas « Le portail de suivi »	
Décision à prendre *L'une des décisions difficiles soulevées*	Malgré la consigne du lead développeur, faut-il faire remonter la faille dès aujourd'hui, et à qui ?
Ce que je sais *Ce que le groupe a affirmé, dans l'exposé ou le débat*	– En modifiant le numéro de suivi dans l'URL, j'ai vu les coordonnées d'autres destinataires, dont un client de la PME ; j'ai fait trois essais et deux captures d'écran. – Le contrat avec Tranzolis est renégocié la semaine prochaine. – La référente RGPD est absente jusqu'à lundi ; le lead développeur demande d'attendre. – En réponse aux questions : le directeur général est joignable aujourd'hui.
Ce que je suppose et ignore *Ce que vous complétez vous-même, ce que vous ignorez ; signalez l'hypothèse décisive*	– **Hypothèse décisive :** Tranzolis est sous-traitant de la PME pour les données de livraison de ses clients. La faille constituerait alors une violation de données, sans doute à notifier à la CNIL dans un délai de 72 heures, qui pourrait courir dès aujourd'hui. – Les numéros de suivi sont attribués dans l'ordre : la faille est facile à trouver et peut être exploitée en ce moment. – Le lead développeur veut éviter un conflit avant la négociation, pas dissimuler la faille. – **J'ignore :** si d'autres ont exploité la faille ; si Tranzolis la connaît déjà ; comment le directeur arbitrera face à la renégociation.
Options envisagées *Au moins deux options défendables*	**1.** Suivre la consigne et attendre lundi. **2.** Alerter aujourd'hui, par écrit, le directeur général (lead développeur en copie), pour que l'entreprise prévienne elle-même Tranzolis. **3.** Prévenir moi-même le support de Tranzolis.
Risques et bénéfices *Pour chaque option : technique, juridique, psychologique*	**Option 1.** *Technique :* la faille reste ouverte au moins quatre jours. *Juridique :* si l'hypothèse décisive est juste, le délai de 72 heures sera dépassé lundi ; mon propre risque pénal reste faible, puisque je me suis arrêtée. *Psychologique :* pas de conflit, mais je serai celle qui savait et n'a rien dit. **Option 2.** *Technique :* correction rapide possible (contrôle d'autorisation sur l'identifiant). *Juridique :* l'entreprise peut notifier à temps ; mon écrit montre ma bonne foi. *Psychologique :* le lead développeur peut s'estimer désavoué ; écrire au directeur général m'intimide. **Option 3.** *Technique :* correction peut-être la plus rapide. *Juridique :* j'agis sans mandat, je transmettrais des données de tiers, et Tranzolis pourrait voir dans mes essais un accès frauduleux. *Psychologique :* rupture de confiance en pleine renégociation, risque disciplinaire.
Décision prise *L'option que vous retenez, assez précise pour être exécutée*	**Option 2.** Avant 18 h, j'envoie au directeur général, lead développeur en copie, un courrier électronique factuel : la manipulation (type d'URL, date, heure), les données visibles, le risque pour les personnes et la question d'une notification à la CNIL. Je propose que l'entreprise prévienne Tranzolis demain matin. Je n'y joins pas les captures : je les transmets à la seule référente RGPD, chargée de documenter l'incident (RGPD, article 33, paragraphe 5), puis je supprime ma copie. Je ne refais aucun test.
Risque accepté *Ce qui peut mal tourner, et pourquoi vous l'acceptez*	– Le lead développeur peut m'en vouloir. Je l'accepte : la décision revient à la direction, qui doit savoir qu'un délai légal court peut-être. – Les captures restent quelques jours dans la messagerie de la référente, absente jusqu'à lundi. Je l'accepte : c'est elle qui doit documenter l'incident, et je n'en garde aucune copie.
Niveau de confiance *Probabilité que votre hypothèse décisive soit exacte (0 à 100 %)*	**75 %.** C'est la probabilité que Tranzolis soit sous-traitant de la PME pour ces données (il pourrait aussi être responsable de son propre portail). Si l'hypothèse était fausse, la violation serait celle de Tranzolis, seul tenu de la notifier, et la PME n'aurait aucun délai à respecter : je choisirais alors l'option 1, sans passer par-dessus le lead développeur, en laissant simplement une trace écrite (un courrier électronique factuel, avant 18 h, à lui et à la référente RGPD).

© Frédéric Connes, 2026 · Tous droits réservés